

Vendor Risk Assessment

Questionnaire, scorecard, residual-risk decision, and remediation terms

Assessment Overview

Sample due-diligence package for evaluating a fictional cloud payroll vendor. The model combines questionnaire responses with inherent-risk and control-effectiveness scoring.

Vendor Profile

Field	Sample Entry
Vendor	CloudPay Systems
Service	Cloud payroll and employee tax processing
Data	Employee PII, bank details, tax identifiers
Criticality	High
Hosting	US-based cloud environment
Assurance	SOC 2 Type II report provided

Security Questionnaire and Scorecard

#	Question	Response	Evidence	Score
1	Is MFA required for privileged and remote access?	Yes	Access-control standard	5
2	Are user access reviews completed at least quarterly?	Partial	Most recent review was 5 months ago	3
3	Are vulnerabilities scanned and remediated to defined SLAs?	Yes	Monthly scan summary	4
4	Is sensitive data encrypted in transit and at rest?	Yes	Architecture diagram and policy	5
5	Has incident response been tested in the last year?	No	No tabletop evidence	1
6	Are critical subcontractors assessed annually?	Partial	Assessment applies only to new vendors	2
7	Are backups tested through restoration exercises?	Yes	Quarterly restore results	4
8	Is cyber insurance maintained?	Yes	Certificate of insurance	4

Risk Decision

Calculated control score: 70%. **Residual risk:** Medium-High. Approve conditionally with a 90-day remediation plan for incident-response testing and subcontractor oversight.

Required Contract Clauses

Breach notification within 24 hours; right to audit; annual assurance reporting; encryption requirements; subcontractor flow-down obligations; secure data deletion at termination; business-continuity testing; and defined service-level commitments.